



Tech99 Innovations Private Limited
(CertifyMe)

System and Organisation Control (SOC 2) Type II Report

**Report on Description of Tech99 Innovations Private Limited and on
Suitability of the Design and Operational Effectiveness of Controls Relevant
to Security, Confidentiality, and Availability**

**For the Audit Period:
February 1, 2026, to April 30, 2026**



PERCILCHOFÉ

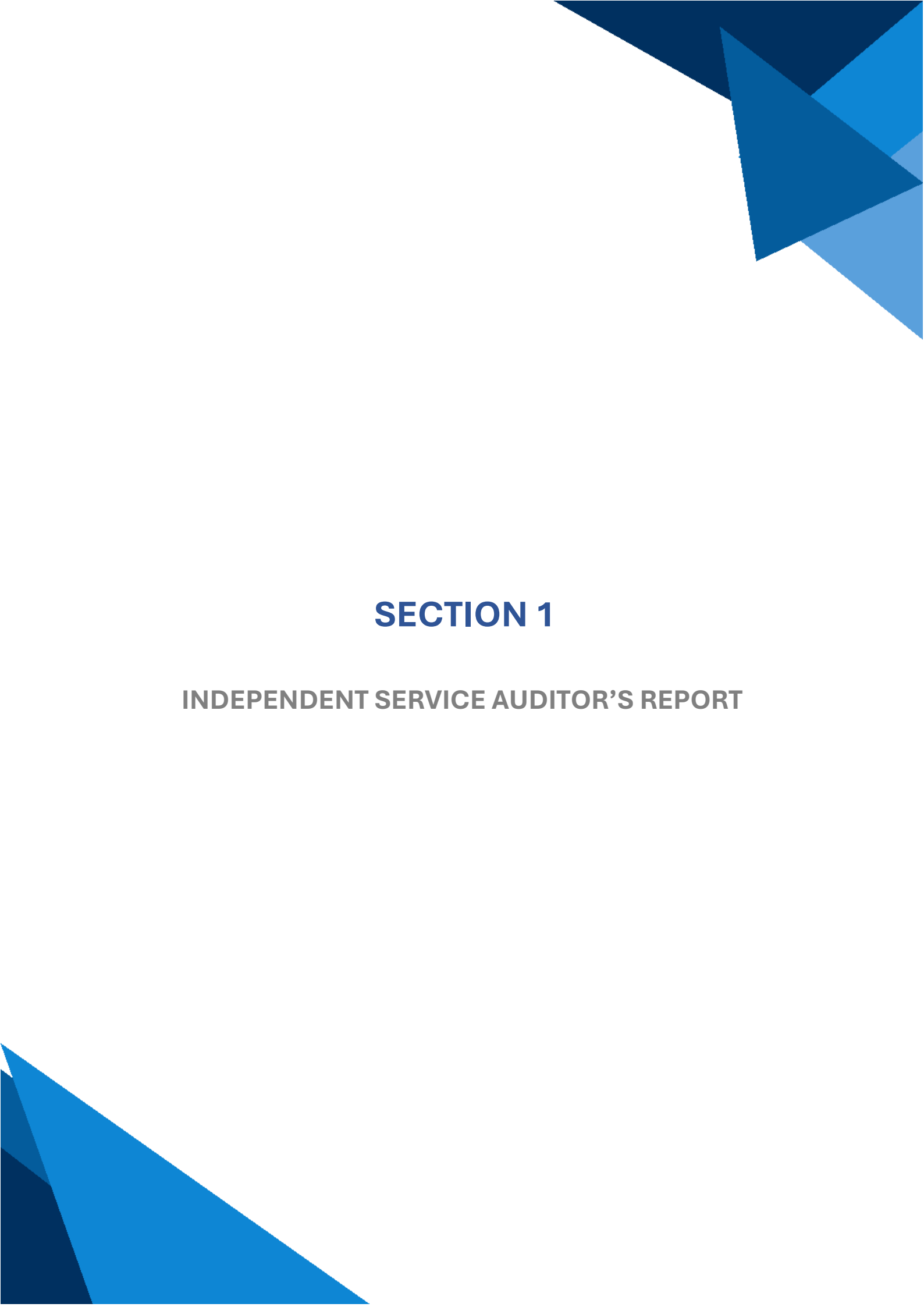
Percilchofe CPA LLC



Table of Contents

Table of Contents	2
Independent Service Auditor's Report	5
Scope	5
Service Organisation's Responsibilities.....	5
Service Auditor's Responsibilities	5
Inherent Limitations.....	6
Opinion	6
Restricted Use	6
Management Assertion Provided by Tech99 Innovations Private Limited	8
3.1 Overview of the Company	10
3.1.1 Operational Role and Business Model.....	10
3.1.2 Strategic Importance and Growth	10
3.2 Scope	10
3.3 Overview of Services	10
3.3.1 Core Functions and Operations	11
3.3.2 Operational Support for Business Units	11
3.4 Principal Service Commitments and System Requirements	11
3.4.1 Encryption and Key Management.....	11
3.4.2 System Boundary and Data Flow	11
System Architecture Overview	12
System Components and Security Controls	12
End-to-End Data Flow	13
Infrastructure and Hosting Details	13
Sub-Service Organisations Supporting CertifyMe.....	13
3.4.3 Use of Amazon Web Services	13
3.5 Relevant Aspects of the Control Environment, Risk Assessment, and Monitoring	14
3.5.1 Control Environment.....	14
3.5.2 Monitoring	14
3.5.3 Information and Communication.....	14
3.5.4 Communication.....	14
3.6 Information Security	15
3.6.1 Logical Access.....	15
3.6.2 Physical Security	15
3.6.3 Change Management	15
3.6.4 Incident Management	15
3.6.5 Third Party Service Delivery	15
3.6.6 Business Continuity Management	16

3.7 Complementary User Entity Controls (CUECs)	16
3.8 Complementary Sub-Service Organisation Controls (CSOCs)	16
4. Trust Services Criteria, Description of Related Controls, Tests of Controls and Results of Tests	19
4.1 SOC 2 Overview	19
4.2 Objectives of the Examination.....	19
4.3 Control Environment Elements	19
4.4 Trust Services Criteria Controls and Tests of Results.....	20



SECTION 1

INDEPENDENT SERVICE AUDITOR'S REPORT



Independent Service Auditor's Report

To the Management of Tech99 Innovations Private Limited:

Scope

We have examined Tech99 Innovations Private Limited's ("the Service Organisation", operating the CertifyMe system) description of its system for the CertifyMe platform throughout the period February 1, 2026 to April 30, 2026 (the "description"), based on the criteria for a description of a service organisation's system set forth in the Description Criteria, and the suitability of the design and operating effectiveness of controls stated in the description throughout the period February 1, 2026 to April 30, 2026 to provide reasonable assurance that the Service Organisation's service commitments and system requirements were achieved based on the trust services criteria relevant to Security, Availability, and Confidentiality (the "applicable trust services criteria") set forth in TSP section 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (with the criteria organised in accordance with the 2022 revised points of focus).

The description indicates that certain applicable trust services criteria can be met only if complementary user-entity controls and complementary sub-service organisation controls assumed in the design of the Service Organisation's controls are suitably designed and operating effectively, along with related controls at the Service Organisation. The examination did not extend to such complementary controls, and we express no opinion on their suitability of design or operating effectiveness.

This report and the description of tests of controls and results thereof in Section 4 are intended solely for the information and use of CertifyMe, user entities of the CertifyMe system during some or all of the period from February 1, 2026, to April 30, 2026, business partners subject to risks arising from interactions with the system, and their auditors.

Service Organisation's Responsibilities

CertifyMe is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that its service commitments and system requirements are achieved. CertifyMe is also responsible for preparing the description and the accompanying assertion, including the completeness, accuracy, and method of presentation of the description and assertion, and for identifying the risks that threaten the achievement of the service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description, based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants (AICPA). Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operating effectively throughout the period February 1, 2026 to April 30, 2026.

An examination of a description of a service organisation's system and the suitability of design and operating effectiveness of controls involves performing procedures to obtain evidence about the presentation of the description, and the suitability of design and operating effectiveness of controls. Our procedures included



assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or operating effectively. Our examination also included evaluating the overall presentation of the description. We believe the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of user entities and may not, therefore, include every aspect of the system that individual user entities may consider important to their own particular needs. Because of their nature, controls at a service organisation may not prevent, or detect and correct, all deviations. Also, the projection to the future of any evaluation of the fairness of the presentation of the description, or conclusions about the suitability of the design or operating effectiveness of controls, is subject to the risk that controls may become inadequate or fail.

Opinion

In our opinion, in all material respects:

- a) The description presents the system for the CertifyMe platform that was designed and implemented for the audit period from February 1, 2026, to April 30, 2026, in accordance with the description criteria.
- b) The controls stated in the description were suitably designed for the audit period from February 1, 2026, to April 30, 2026, to provide reasonable assurance that CertifyMe's commitments and system requirements would be achieved based on the applicable trust services criteria if its controls operated effectively as of that date.

Restricted Use

This report is intended solely for the information and use of the parties specified above and is not intended to be, and should not be, used by anyone other than these specified parties.

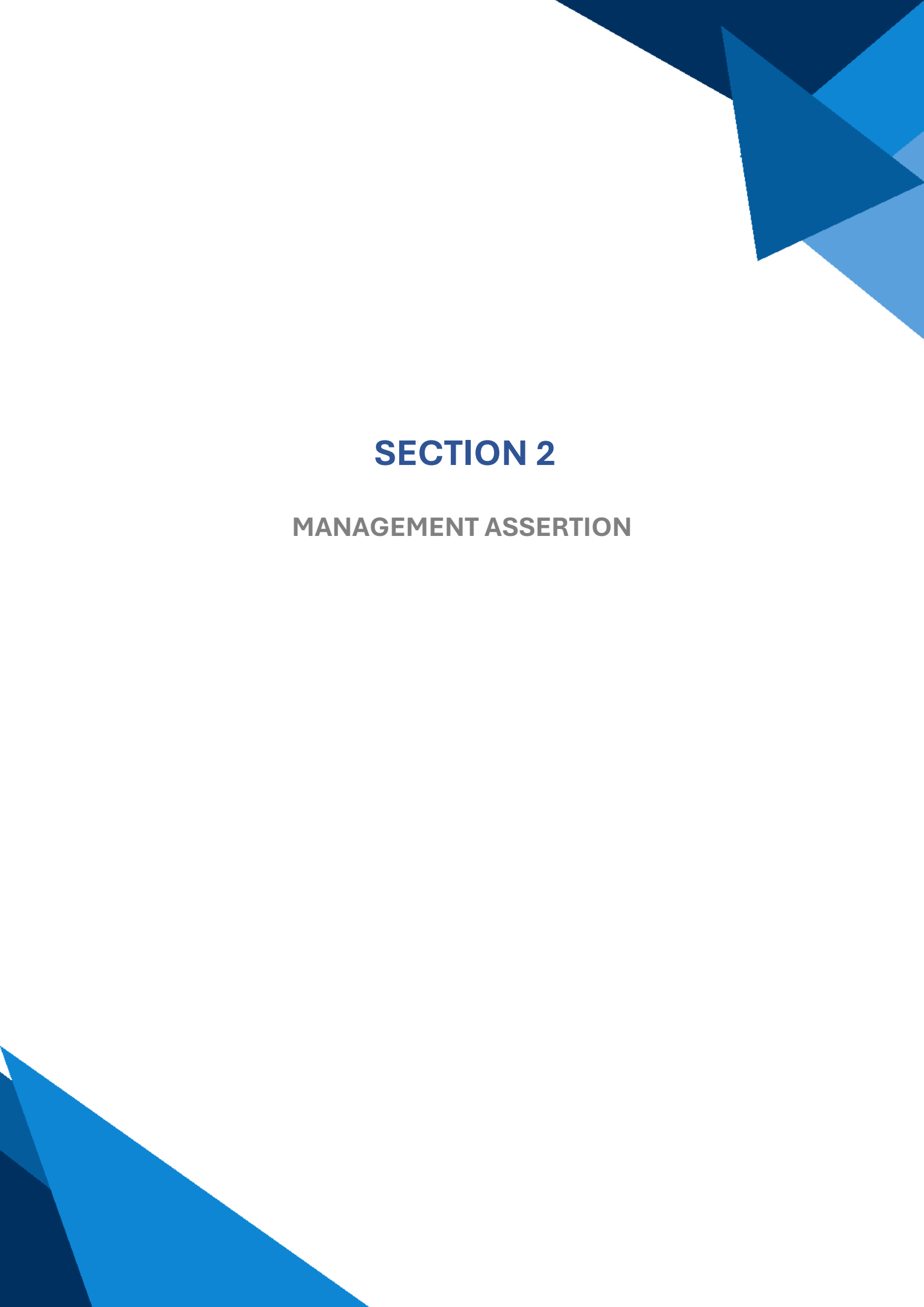
Percilchofe CPA LLC

Digitally signed by Percilchofe CPA
LLC
Date: 2026.07.22 16:43:08 +05'30'

Percilchofe CPA LLC

License No.: 1188

Date: July 22, 2026



SECTION 2

MANAGEMENT ASSERTION

Management Assertion Provided by Tech99 Innovations Private Limited

Management Assertion Provided by Tech99 Innovations Private Limited

We have prepared the accompanying description of the CertifyMe system throughout the period from February 1, 2026, to April 30, 2026 (the "description") based on the criteria for a description of a service organisation's system set forth in the Description Criteria. The description is intended to provide report users with information about the CertifyMe system that may be useful when assessing the risks arising from interactions with the system, particularly information about system controls that Tech99 Innovations Private Limited has designed, implemented and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to Security, Availability, and Confidentiality (the "applicable trust services criteria").

We confirm, to the best of our knowledge and belief, that:

- The description presents the CertifyMe system that was designed and implemented throughout the period from February 1, 2026, to April 30, 2026, in accordance with the description criteria;
- The controls stated in the description were suitably designed throughout the period from February 1, 2026, to April 30, 2026, to provide reasonable assurance that the service commitments and system requirements would be achieved based on the applicable trust services criteria, if the controls operated effectively and if user entities and sub-service organisations applied the complementary controls assumed in the design of the controls throughout that period; and
- The controls stated in the description operated effectively throughout the period from February 1, 2026, to April 30, 2026, to provide reasonable assurance that the service commitments and system requirements were achieved based on the applicable trust services criteria for the controls within the scope of this report.

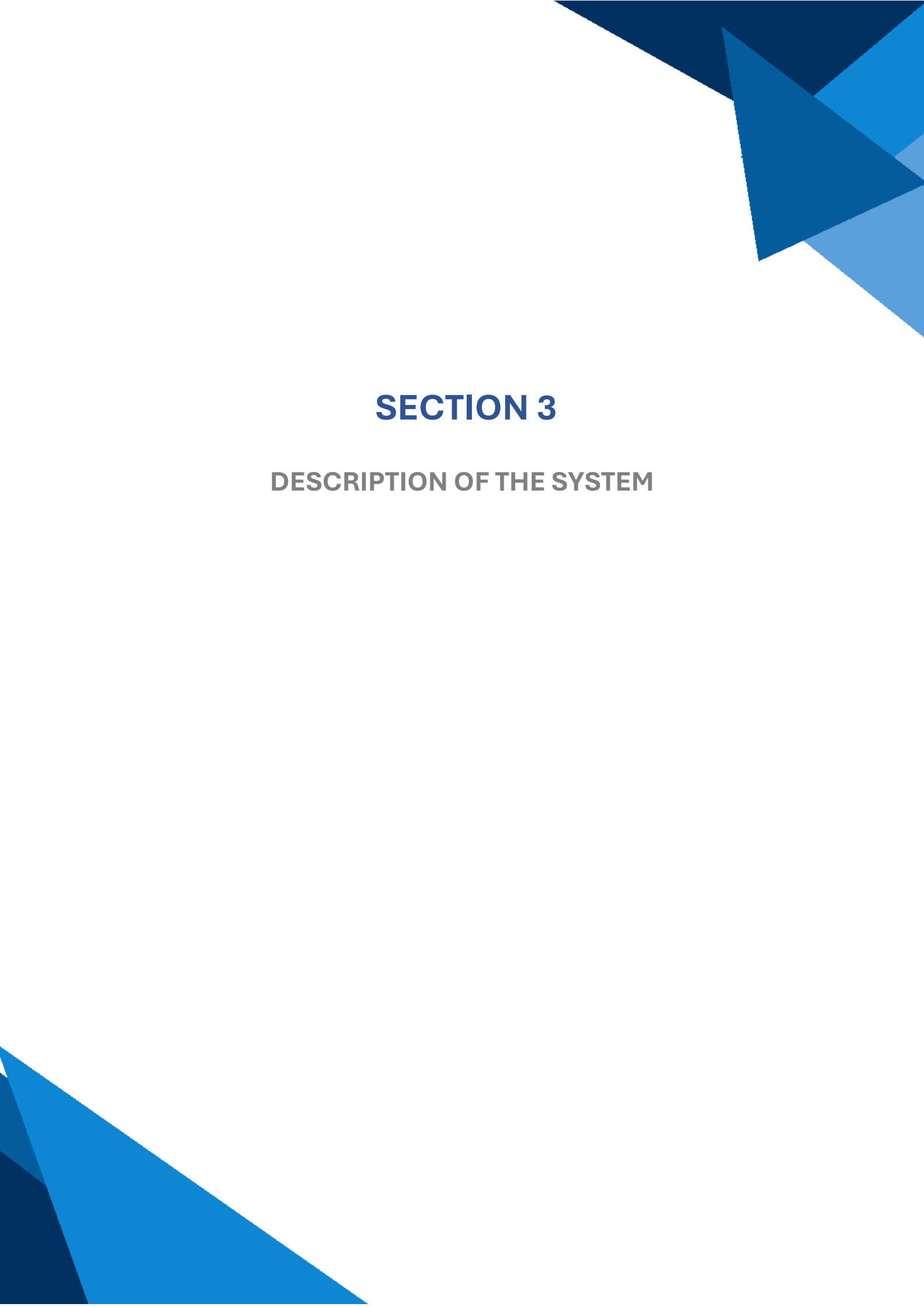
For and on behalf of Tech99 Innovations Private Limited



Name: Ranjith THARAYIL

Designation: Director

Date: 16 July 2026



SECTION 3

DESCRIPTION OF THE SYSTEM

3.1 Overview of the Company

Tech99 Innovations Private Limited (referred to throughout this section by its brand name, CertifyMe) is a technology company incorporated in India on 30 September 2021 (CIN U72900KA2021PTC152542), headquartered at Akshay Tech Park, EPIP Zone, Whitefield, Bengaluru, Karnataka, with an additional office in San Francisco, California. CertifyMe operates a cloud-based Software-as-a-Service (SaaS) platform for the creation, issuance, management and verification of verifiable digital credentials, digital certificates and badges, which is the system covered by this report.

3.1.1 Operational Role and Business Model

CertifyMe provides an end-to-end digital credentialing platform delivered on a subscription (SaaS) basis to institutions across higher education, professional associations, e-learning providers, and corporate learning-and-development functions. Issuing institutions use the platform to design, issue, and manage digital certificates and badges that recipients can store, share, and present for independent verification. The platform issues credentials aligned to the Open Badges 3.0 and W3C Verifiable Credentials standards and supports adjacent services including learner e-portfolios and academic transcript management.

3.1.2 Strategic Importance and Growth

Per the service organisation's public disclosures, the platform is used by institutions across 140+ countries and is independently recognised in third-party software review categories for digital credential management. CertifyMe states that it maintains ISO 27001 (information security), ISO 27701 (privacy) and ISO 9001 (quality) certifications and operates in alignment with GDPR, FERPA and COPPA. [The company states these certifications are not the subject of, and are not opined on in, this SOC 2 report.]

3.2 Scope

This report covers the CertifyMe system and the controls supporting the trust services criteria for Security, Availability, and Confidentiality throughout the examination period, February 1, 2026, to April 30, 2026. The examination period is stated as per the system description and the executed engagement letter.

The in-scope operating locations, as confirmed by management, are the data centres in which all applications, data processing and storage within the scope of this examination occur: APAC (Bangalore), EU (Frankfurt), and US (New York). The system is hosted across the DigitalOcean US1, EU2 and APAC regions.

Physical and environmental security is out of the scope of CertifyMe's own controls: the CertifyMe system is hosted by DigitalOcean, LLC, and the physical and environmental protection of the hosting facilities is the responsibility of that sub-service organisation (see Section 3.8). This is consistent with the control set, in which the physical and environmental security controls are recorded as not applicable to CertifyMe.

3.3 Overview of Services

The CertifyMe system provides the following principal capabilities: credential design and bulk issuance; a recipient credential wallet; independent verification of each credential through a cryptographic digital signature and a unique QR code or verification URL (verifiable without contacting CertifyMe); white-labelled, branded credential experiences; credential analytics; and an optional blockchain anchor for institutions requiring an immutable verification trail.

3.3.1 Core Functions and Operations

The core functions of the system are (a) credential issuance, performed by the issuance engine in accordance with the Open Badges 3.0 / W3C Verifiable Credentials data models; (b) credential verification, performed by the verification service using RSA and Ed25519 digital signatures; and (c) credential storage and presentation through the recipient wallet. Consistent with a data-minimisation approach, the service organisation states that credentials can be issued without requiring sensitive learner personal data such as email addresses.

3.3.2 Operational Support for Business Units

The platform exposes a REST API with webhooks and supports enterprise integration through SSO/SAML, SCIM provisioning, and connectors to learning-management systems (e.g. Canvas, Moodle), CRM systems (e.g. Salesforce), and student-information/HR systems (e.g. Workday). These integrations enable institutions to automate issuance from their existing systems of record.

3.4 Principal Service Commitments and System Requirements

Service commitments and system requirements are established by CertifyMe and communicated in customer agreements and internal policies. Security, availability and confidentiality commitments are supported by the documented policy set (including the Information Security Policy, Access Control Policy, Encryption and Key Management Policy, Business Continuity and Disaster Recovery Policy, and Data and Record Retention and Deletion Policy), and by a 99.9% uptime service-level commitment for enterprise customers.

3.4.1 Encryption and Key Management

As confirmed by management, encryption is implemented as follows:

- Data at rest is encrypted using AES-256, applied at the infrastructure layer by the DigitalOcean Managed Database service.
- Key management: encryption keys are provider-managed (DigitalOcean-managed KMS). No customer-managed keys are in use, and no additional customer-managed encryption configuration is required.
- Data in transit: encrypted using TLS 1.2 or higher, enforced at the Cloudflare edge and through to the application layer.
- Database: the in-scope database is a DigitalOcean Managed Database, deployed within a private subnet of the VPC with no public access and protected by DigitalOcean Cloud Firewalls; access is restricted to authorised application servers. Encryption at rest is applied automatically as part of the managed service.

3.4.2 System Boundary and Data Flow

The reviewed and approved network diagram provided by the service organisation is reproduced below. It presents the system boundary and the principal data flows between user entities, the Cloudflare edge, the DigitalOcean production environment, and the underlying infrastructure.

End users, integrating organisations, API clients and public certificate verifiers reach the system over HTTPS (TLS 1.2 or higher). Traffic terminates at the Cloudflare edge, which provides DNS, CDN, web application firewall, OWASP Top 10 protection, DDoS protection, rate limiting, bot management, IP reputation filtering

and SSL/TLS termination. Cloudflare provides edge security, CDN and DNS only; it does not host the application or the database. Secure traffic is then passed to the DigitalOcean production environment.

Within DigitalOcean, the production environment is deployed inside a Virtual Private Cloud (VPC). A public subnet contains a load balancer (HAProxy) which distributes traffic to the web and application server droplets running the application stack. A private subnet forms the data layer, containing the DigitalOcean Managed Database (high availability, automated backups, private networking) and DigitalOcean Spaces, an S3-compatible object storage service used for object storage, backups, exports, and media files. Network security is enforced through DigitalOcean Cloud Firewalls (stateful, with inbound and outbound rules, droplet protection and database protection) and private VPC networking with isolated subnets, internal routing and no public database access.

Monitoring and management comprise DigitalOcean monitoring, alerts and notifications, infrastructure management, centralised log and metrics collection, and automated backups.

System Architecture Overview

CertifyMe is a credentialing platform accessed via the public internet by three categories of users: individual end users, partner organisations, and system-to-system integrations/API clients. All traffic is encrypted in transit and is terminated through a layered set of controls before reaching application logic and again before reaching data storage. The system is organised into four logical zones:

Users / Actors - the external parties that initiate traffic into the system.

Public Endpoint - the internet-facing edge, provided by Cloudflare, that handles DNS, CDN, DDoS protection, and web application firewalling.

Application / Cloud Environment - the CertifyMe credentialing service and its supporting application components.

Data Layer (Private) - the network firewall and database that store and protect credentialing data, with no public access.

System Components and Security Controls

Users / Actors: Three actor types interact with the system, all over HTTPS (TLS 1.2+): End Users, Organizations, and Integrations / API Clients. No actor connects directly to the application or data layer; all traffic is routed through the public endpoint first.

Public Endpoint - Cloudflare: Cloudflare is the sole internet-facing entry point and provides DNS resolution, CDN, and DDoS protection. All inbound connections use HTTPS with TLS 1.2 or higher. Cloudflare's Web Application Firewall (WAF) inspects traffic before it is allowed to proceed, providing OWASP Top 10 protection, rate limiting, bot management, IP reputation filtering, and SSL/TLS termination.

Application / Cloud Environment: This zone hosts the CertifyMe Credentialing Service, which enforces separate inbound and outbound rule sets. Inbound rules allow HTTPS (443) from Cloudflare IP ranges only, deny all other inbound traffic, validate request headers and tokens, enforce rate limiting, perform WAF-style input validation, and maintain logging and monitoring. Outbound rules allow database connections to the private database (private IP, port 5432) and required external services, while denying all other outbound traffic with egress filtering and logging.

Data Layer (Private): The data layer is not publicly reachable. It is protected by a dedicated network firewall positioned in front of the database, allowing traffic from the credentialing service (private IP) on port 5432 only, denying all other traffic, performing stateful inspection of all sessions, and maintaining logging and monitoring of all connections.

End-to-End Data Flow

1. A user, organization, or integration client initiates an HTTPS (TLS 1.2+) request.
2. Cloudflare resolves DNS, absorbs volumetric/DDoS attempts, and passes the request through the WAF.
3. Traffic that passes inspection is forwarded as allowed HTTPS traffic to the credentialing service.
4. The credentialing service applies inbound rules before processing the request.
5. If data access is required, the credentialing service initiates an outbound connection to the database on port 5432 only.
6. The network firewall in front of the data layer allows only this specific connection and denies everything else, with stateful inspection and logging.
7. The database, in a private subnet with no public access, processes the request and returns data back along the same path.

Infrastructure and Hosting Details

Cloud Hosting Provider: DigitalOcean

Deployment Regions: APAC, EU2, US1

Database: DigitalOcean Managed Database (PostgreSQL), encrypted at rest with AES-256, deployed in a private subnet with no public access

Encryption at Rest: AES-256, applied at the infrastructure layer by the DigitalOcean Managed Database service

Key Management: DigitalOcean-managed KMS

Data in Transit: TLS 1.2 or higher, enforced at Cloudflare edge and through the application layer

Backups: Automated, retained in accordance with the Data and Record Retention and Deletion Policy

Sub-Service Organisations Supporting CertifyMe

- DigitalOcean, LLC - Cloud infrastructure hosting - All application and database data (encrypted at rest and in transit).
- Cloudflare, Inc. - DNS, CDN, DDoS protection, WAF - Network-layer traffic metadata; no data-layer access.

3.4.3 Use of Amazon Web Services

Management has confirmed in writing, and the reviewed and approved network diagram states, that Amazon Web Services is not used within the in-scope production environment. References to “S3” relate to DigitalOcean Spaces object storage, which exposes an S3-compatible API. There are no AWS compute, storage, database, networking or email services within the audited environment.

CertifyMe – Network Diagram

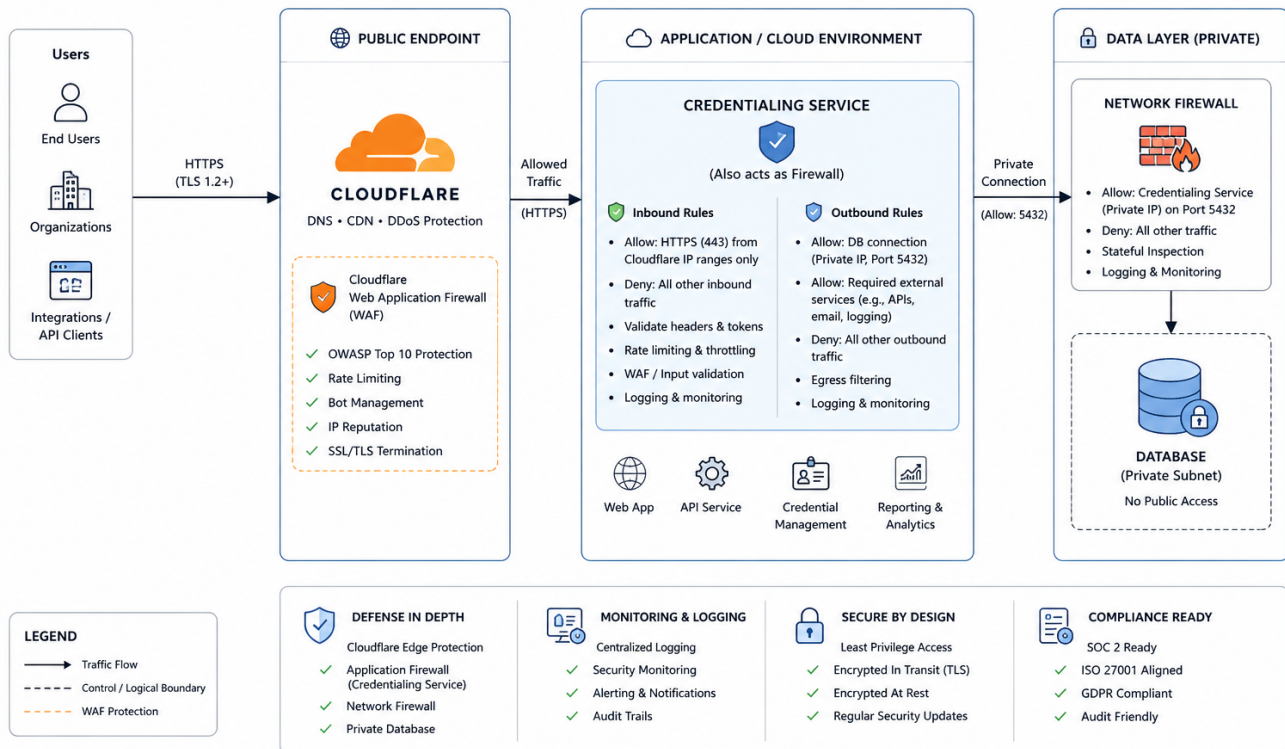


Figure 1 CertifyMe network diagram.

3.5 Relevant Aspects of the Control Environment, Risk Assessment, and Monitoring

3.5.1 Control Environment

The control environment is established through published security and privacy documentation, assigned security responsibilities, and defined roles and responsibilities.

3.5.2 Monitoring

Monitoring is performed through centralized collection of security event logs, protection of audit records, and monitoring for anomalous behaviour.

3.5.3 Information and Communication

Information relevant to the operation of controls is captured through centralized logging, and security responsibilities are communicated to personnel through defined roles, terms of employment, and rules of behaviour.

3.5.4 Communication

Security obligations are communicated externally through third-party contract requirements.

3.6 Information Security

3.6.1 Logical Access

Logical access is governed through role-based access control, least privilege, access enforcement, privileged account management, and revocation of access authorisations, with enterprise authentication supported through SSO/SAML and SCIM provisioning.

As confirmed by management, the password policy enforced at account signup for all users requires a minimum length of eight characters and must include at least one uppercase letter, one lowercase letter, one number, and one special character.

Multi-factor authentication is enforced across the in-scope administrative environments. Google Workspace 2-Step Verification is configured with enforcement set to “On” for the Tech99 Innovations Private Limited organisational unit, with device trust disabled. The DigitalOcean team account enforces Secure Sign-In, requiring team members to authenticate via Google, GitHub, or a 2FA-protected DigitalOcean account. Multi-factor authentication is additionally enabled at the user level within the CertifyMe administrative application.

3.6.2 Physical Security

Physical and environmental security of the hosting facilities — including physical access control, environmental monitoring, cooling systems, battery/generator backup power, and fire detection and suppression across the US1, EU2 and APAC regions — is the responsibility of DigitalOcean, LLC and is addressed as a complementary sub-service organisation control under the carve-out method described in Section 3.8, meaning these controls are excluded from the scope of this examination and were not tested. CertifyMe does not operate, lease, or otherwise control any in-scope physical data-centre facilities.

3.6.3 Change Management

Application and infrastructure changes are governed by a documented change management programme that requires changes to be authorised through configuration change control procedures, tested and validated prior to implementation, and formally documented. Affected stakeholders are notified of changes as part of this process. Application changes are further governed by a secure development life cycle (SDLC) that incorporates secure coding practices during development, providing coverage from initial design and coding through testing, approval and deployment.

3.6.4 Incident Management

Incident response operations are established through documented incident response procedures and an Incident Register used to record, evaluate and track security events, data breaches and unauthorised access attempts.

3.6.5 Third Party Service Delivery

Risks arising from third-party and vendor relationships are governed through a documented third-party management programme, supported by a maintained inventory of third-party services. Security obligations are communicated to external parties through contractual requirements embedded in third-party agreements, and third-party services are subject to periodic review to identify changes that may affect risk to CertifyMe's environment.

3.6.6 Business Continuity Management

Availability of the CertifyMe system is supported by ongoing performance and capacity monitoring, a redundant secondary system providing recovery capability, and periodic contingency plan testing and exercises to validate recovery procedures. These control activities operate alongside DigitalOcean's redundancy, replication and resilience of the underlying hosting infrastructure (Section 3.8), consistent with CertifyMe's stated 99.9% uptime service-level commitment for enterprise customers.

3.7 Complementary User Entity Controls (CUECs)

The controls at CertifyMe were designed with the assumption that user entities would implement certain complementary controls. The following CUECs are assumed:

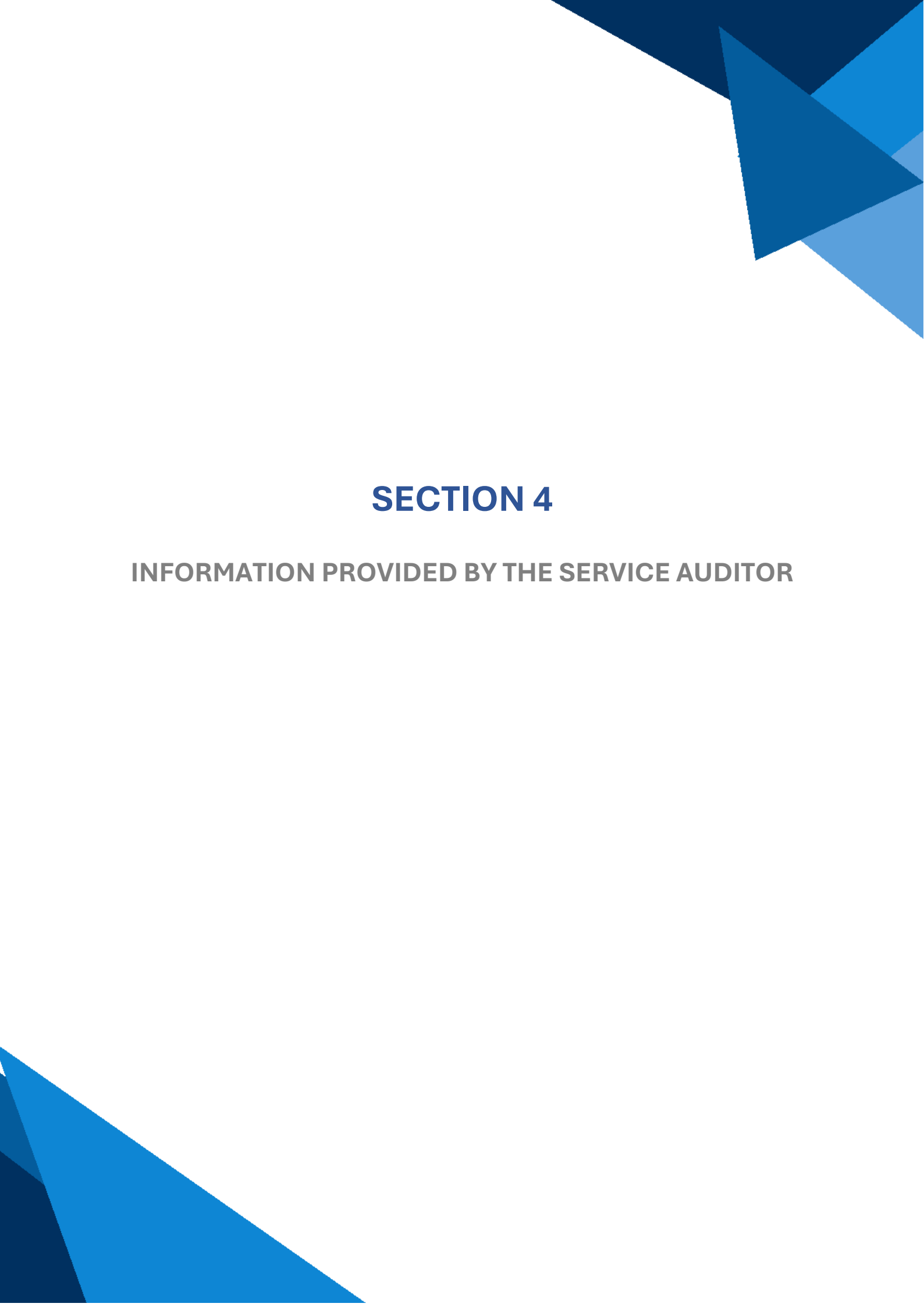
No.	Complementary User Entity Control
1	User entities are responsible for provisioning, reviewing and de-provisioning their own users' access to the CertifyMe application and for enforcing their internal authorisation processes.
2	User entities are responsible for maintaining the confidentiality of authentication credentials issued to their personnel and for enabling available account-protection features.
3	User entities are responsible for promptly notifying CertifyMe of any actual or suspected security incident, unauthorised access, or misuse involving their account.
4	User entities are responsible for ensuring the accuracy, legality and appropriateness of data they submit to or process within the CertifyMe system.
5	User entities are responsible for configuring available security options within the application in line with their own internal policies and regulatory obligations.

3.8 Complementary Sub-Service Organisation Controls (CSOCs)

The CertifyMe system is hosted by DigitalOcean, LLC (the “sub-service organisation”) across its US1, EU2 and APAC regions. This report uses the carve-out method: the controls of DigitalOcean, LLC are excluded from the scope of this examination and are not tested. The following CSOCs are assumed to be in place and operating effectively at the sub-service organisation:

No.	Sub-Service Organisation	Complementary Control
1	DigitalOcean, LLC	Physical and environmental protections of the data-centre facilities (physical access control, monitoring, cooling systems, battery/generator backups, fire detection and suppression) across the US, EU and APAC regions.
2	DigitalOcean, LLC	Redundancy, replication and resilience of the underlying hosting infrastructure supporting availability of the CertifyMe system.

No.	Sub-Service Organisation	Complementary Control
3	DigitalOcean, LLC	Logical and network isolation of the underlying multi-tenant hosting platform, and encryption of data at rest (AES-256) applied at the infrastructure layer by the Managed MySQL service, including management of the associated encryption keys.



SECTION 4

INFORMATION PROVIDED BY THE SERVICE AUDITOR



4. Trust Services Criteria, Description of Related Controls, Tests of Controls and Results of Tests

4.1 SOC 2 Overview

This section presents the applicable trust services criteria for Security, Availability, and Confidentiality, the controls implemented by CertifyMe to meet those criteria, the tests performed by the service auditor, and the results of those tests, throughout the period from February 1, 2026, to April 30, 2026.

4.2 Objectives of the Examination

The objective of the examination was to evaluate the suitability of the design and the operating effectiveness of controls throughout the examination period to provide reasonable assurance that CertifyMe's service commitments and system requirements were achieved based on the applicable trust services criteria.

4.3 Control Environment Elements

The controls presented below are organised by trust services criteria reference. Each control activity is presented as a distinct control with its own test procedure and result. Control activities assessed as non-compliant or not applicable during the examination have been excluded from the tested control set presented in Section 4.4.



4.4 Trust Services Criteria Controls and Tests of Results

TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC1.1	COSO Principle 1: Demonstrates commitment to integrity and ethical values.	Security & privacy documentation (policies incl. Code of Conduct) is formally published and made available to personnel.	Inspected the published policy set covering the examination period (February 1, 2026 to April 30, 2026) and confirmed that the Code of Conduct and security policies were formally approved and remained accessible to personnel throughout the period.	No Exceptions Noted
CC1.2	COSO Principle 2: Board exercises oversight of internal control.	Security & privacy responsibilities are formally assigned to accountable roles.	Inspected the Information Security Roles & Responsibilities documentation in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed that ownership of security oversight remained clearly defined and assigned throughout the period.	No Exceptions Noted
CC1.3	COSO Principle 3: Establishes structures, reporting lines, authorities and responsibilities.	Business context and mission are defined to establish the scope and structure of the security programme.	Inspected the governance documentation in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed that it continued to define the business context, mission and organisational structure supporting the security programme.	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC1.4	COSO Principle 4: Demonstrates commitment to competence.	A security- and privacy-minded workforce is maintained through defined workforce expectations.	Inquired of management and obtained written confirmation that no new personnel joined the service organisation during the examination period from February 1, 2026 to April 30, 2026 (two personnel separated during the period). Accordingly, no instances of personnel screening arose during the period and there was no population available for testing.	No Exceptions Noted
CC1.5	COSO Principle 5: Enforces accountability.	Terms of employment and rules of behaviour hold personnel accountable for security responsibilities.	Inspected the employment terms and rules-of-behaviour documentation in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed that it continued to establish personnel accountability for security responsibilities.	No Exceptions Noted
CC2.1	COSO Principle 13: Uses relevant, quality information.	Security event logs are centrally collected to provide quality information for control operation.	Inspected the centralised log collection configuration and confirmed that security event logs continued to be aggregated throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC2.2	COSO Principle 14: Communicates internally.	Roles & responsibilities are defined and communicated to personnel.	Inspected the role and responsibility documentation and confirmed it remained communicated to personnel throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC2.2b	COSO Principle 14: Communicates internally.	Security awareness is reinforced through user-awareness expectations.	Inspected the user-awareness materials and confirmed they continued to be provided to personnel throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC2.3	COSO Principle 15: Communicates externally.	Third-party contract requirements define security obligations communicated to external parties.	Inspected the third-party contract requirement templates in use throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed they continued to specify security obligations communicated to external parties.	No Exceptions Noted
CC3.1	COSO Principle 6: Specifies suitable objectives.	Statutory, regulatory & contractual compliance obligations are identified to frame control objectives.	Inspected the compliance obligations register maintained throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed it continued to identify applicable statutory, regulatory and contractual requirements.	No Exceptions Noted
CC3.4	COSO Principle 9: Identifies and assesses changes.	Third-party services are reviewed to identify changes affecting risk.	Inspected records of third-party service reviews performed during the examination period (February 1, 2026 to April 30, 2026) and confirmed reviews were conducted to identify changes affecting risk.	No Exceptions Noted
CC4.1	COSO Principle 16: Selects, develops and performs evaluations.	Security assessments are performed to evaluate control operation.	Inspected the security assessment records completed during the examination period (February 1, 2026 to April 30, 2026) and confirmed assessments were performed to evaluate control operation.	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC4.1b	COSO Principle 16: Selects, develops and performs evaluations.	Audit activities are conducted over the control environment.	Inspected the audit activity records covering the control environment during the examination period (February 1, 2026 to April 30, 2026) and confirmed audit activities were conducted.	No Exceptions Noted
CC5.1	COSO Principle 10: Selects and develops control activities.	The security & privacy programme is periodically reviewed and updated.	Inspected evidence of periodic review and update of the security and privacy programme performed during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC5.2	COSO Principle 11: Selects and develops general controls over technology.	Resources are allocated to support security control activities.	Inspected records evidencing allocation of resources to the security programme throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC5.3	COSO Principle 12: Deploys through policies and procedures.	Security & privacy controls oversight deploys policy through defined procedures.	Inspected the policy framework in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed that controls continued to be deployed through documented procedures.	No Exceptions Noted
CC6.1	Logical access security restricts access to protect information assets.	Access enforcement mechanisms restrict system access to authorised users.	Inspected the access enforcement configuration and confirmed it continued to restrict system access to authorised users throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC6.1b	Logical access security restricts access to protect information assets.	Role-based access control (RBAC) governs access assignment.	Inspected the role-based access control (RBAC) configuration and confirmed that access continued to be assigned by defined roles throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC6.1c	Logical access security restricts access to protect information assets.	Data at rest is encrypted to protect stored information.	Inspected the encryption-at-rest configuration for in-scope data stores as configured throughout the examination period (February 1, 2026 to April 30, 2026). Data at rest is encrypted using AES-256, applied at the infrastructure layer by the DigitalOcean Managed Database service. Encryption keys are provider-managed (DigitalOcean-managed KMS); no customer-managed keys are in use. [Database engine to be confirmed: management's written response of 8 July 2026 states Managed MySQL, whereas the reviewed and approved network diagram states Managed PostgreSQL.]	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC6.1d	Logical access security restricts access to protect information assets.	Databases are encrypted to protect stored data.	Inspected the database encryption configuration as maintained throughout the examination period (February 1, 2026 to April 30, 2026). The in-scope database is a DigitalOcean Managed Database residing in a private subnet (VPC) with no public access; AES-256 encryption at rest is applied automatically at the infrastructure level as part of the managed service. [Engine to be confirmed — see note at CC6.1c.]	No Exceptions Noted
CC6.2	Registers and authorises new users prior to granting access.	Privileged account management (PAM) governs the authorisation of privileged access.	Inspected privileged account management records and obtained written confirmation from management that no privileged access was newly granted during the examination period from February 1, 2026 to April 30, 2026, and that existing privileged accounts remained unchanged. Corroborated by inspection of the DigitalOcean team membership. Accordingly, no instances of privileged access provisioning arose during the period and there was no population available for testing.	No Exceptions Noted
CC6.3b	Authorises, modifies, or removes access based on roles.	Access authorisations are revoked when no longer required.	Inspected revocation records for access authorisations processed during the examination period (February 1, 2026 to April 30, 2026) and confirmed that access was revoked when no longer required.	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC6.3c	Authorises, modifies, or removes access based on roles.	Least privilege is enforced across access assignments.	Inspected access assignments in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed that least-privilege enforcement was maintained.	No Exceptions Noted
CC6.3d	Authorises, modifies, or removes access based on roles.	Separation of duties (SoD) is maintained across conflicting functions.	Inspected the role definitions in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed that separation of duties was maintained over conflicting functions.	No Exceptions Noted
CC6.6	Implements boundary protection measures against external threats.	Network access to privileged accounts is restricted.	Inspected the controls restricting network access to privileged accounts and confirmed they remained in place throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC6.6b	Implements boundary protection measures against external threats.	Boundary protection controls the network perimeter.	Inspected the network architecture in place throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed that perimeter traffic terminates at the Cloudflare edge and traverses DigitalOcean Cloud Firewalls (stateful, with inbound/outbound rules) before reaching application servers.	No Exceptions Noted
CC6.6c	Implements boundary protection measures against external threats.	Network security controls (NSC) are deployed.	Inspected the network security controls (NSC) deployed throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC6.6d	Implements boundary protection measures against external threats.	A web application firewall (WAF) protects public-facing applications.	Inspected the reviewed and approved network diagram, current throughout the examination period (February 1, 2026 to April 30, 2026), and confirmed that a web application firewall is deployed at the Cloudflare edge, providing WAF, OWASP Top 10 protection, DDoS protection, rate limiting and bot management for public-facing traffic.	No Exceptions Noted
CC6.6e	Implements boundary protection measures against external threats.	Network segmentation isolates external-facing services from the data layer.	Inspected the network architecture in place throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed segmentation within the VPC between a public subnet (load balancer and application droplets) and a private subnet (managed database and object storage), with no public database access.	No Exceptions Noted
CC6.7	Restricts the transmission, movement, and removal of information.	Remote access is controlled and secured.	Inspected the remote access configuration in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed secured connectivity. Data in transit is encrypted using TLS 1.2 or higher, enforced at the Cloudflare edge and through to the application layer.	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC6.7b	Restricts the transmission, movement, and removal of information.	Data loss prevention (DLP) restricts unauthorised movement of data.	Inspected the data loss prevention (DLP) configuration and confirmed it continued to restrict unauthorised data movement throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC6.7c	Restricts the transmission, movement, and removal of information.	Removable media security controls restrict data removal.	Inspected the removable media security controls and confirmed they remained in place throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC6.7d	Restricts the transmission, movement, and removal of information.	Data flow is enforced through access control lists.	Inspected the access control list (ACL) configuration and confirmed it continued to enforce permitted data flows throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC6.7e	Restricts the transmission, movement, and removal of information.	Traffic is denied by default and allowed by exception.	Inspected the firewall rule-base in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed a default-deny posture, with traffic denied by default and allowed only by exception.	No Exceptions Noted
CC6.8	Prevents or detects unauthorised or malicious software.	Malicious code protection (anti-malware) is deployed to endpoints.	Inspected the anti-malware deployment and configuration on endpoints and confirmed it remained in place throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC6.8b	Prevents or detects unauthorised or malicious software.	Software installation without privileged status is prohibited.	Inspected the endpoint configuration and confirmed it continued to prevent software installation without privileged status throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC6.8c	Prevents or detects unauthorised or malicious software.	A software firewall is enabled on endpoints.	Inspected the endpoint software firewall configuration and confirmed it remained enabled throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC7.1	Detects and monitors for new vulnerabilities.	External vulnerability assessment scans are performed.	Inspected the external vulnerability assessment scan reports generated during the examination period (February 1, 2026 to April 30, 2026) and confirmed scans were performed.	No Exceptions Noted
CC7.1b	Detects and monitors for new vulnerabilities.	Continuous vulnerability remediation activities are performed.	Inspected records of continuous vulnerability remediation activity performed during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC7.1c	Detects and monitors for new vulnerabilities.	Penetration testing is conducted.	Inspected the penetration test report covering the examination period (February 1, 2026 to April 30, 2026) and confirmed that testing was conducted.	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC7.2	Monitors system components for anomalies.	Anomalous behaviour is monitored.	Inspected the monitoring configuration and confirmed it continued to detect anomalous behaviour throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC7.2b	Monitors system components for anomalies.	Audit records capture defined content for monitoring.	Inspected the audit record content configuration and confirmed it continued to capture defined content for monitoring throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC7.2c	Monitors system components for anomalies.	Event logs are protected against tampering.	Inspected the log protection configuration and confirmed event logs remained protected against tampering throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC7.2d	Monitors system components for anomalies.	Performance is monitored to detect degradation.	Inspected the performance monitoring dashboards and alerts and confirmed they continued to detect performance degradation throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC7.3	Evaluates security events to determine response.	Incident response operations are established to evaluate and respond to events.	Inspected the incident response operations documentation and the Incident Register (version 1, released 20 April 2026), which contained no recorded incidents. Obtained a written confirmation signed by the Director (Ref. CM-MS-0002) stating that no security incidents, data breaches, or unauthorised access events were experienced, detected or recorded during the period 1 February 2026 to 30 April 2026.	No Exceptions Noted
CC7.4	Remediates identified vulnerabilities.	A defined vulnerability remediation process governs remediation.	Inspected the vulnerability remediation process and supporting records maintained throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC7.5	Identifies, develops, and implements recovery activities.	Software & firmware patching restores components to a secure state.	Inspected patch management records for in-scope components maintained during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC8.1	Authorises, designs, tests, approves, and implements changes.	A change management programme governs system changes.	Inspected the change management programme documentation in effect throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC8.1b	Authorises, designs, tests, approves, and implements changes.	Configuration change control governs authorisation of changes.	Inspected a sample of change tickets raised during the examination period (February 1, 2026 to April 30, 2026) evidencing authorisation.	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
CC8.1c	Authorises, designs, tests, approves, and implements changes.	Changes are tested, validated and documented.	Inspected a sample of changes made during the examination period (February 1, 2026 to April 30, 2026) evidencing testing, validation and documentation.	No Exceptions Noted
CC8.1d	Authorises, designs, tests, approves, and implements changes.	Stakeholders are notified of changes.	Inspected records of stakeholder change notifications issued during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC8.1e	Authorises, designs, tests, approves, and implements changes.	A secure development life cycle governs application changes.	Inspected the SDLC documentation in effect throughout the examination period (February 1, 2026 to April 30, 2026) and confirmed it continued to govern application changes.	No Exceptions Noted
CC8.1f	Authorises, designs, tests, approves, and implements changes.	Secure coding practices are applied during development.	Inspected the secure coding standards and evidence of their application during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC9.2	Assesses and manages risks associated with vendors and business partners.	A third-party management programme governs vendor risk.	Inspected the third-party management programme documentation in effect throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
CC9.2b	Assesses and manages risks associated with vendors and business partners.	A third-party inventory is maintained.	Inspected the third-party inventory maintained throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
A1.1	Maintains, monitors, and evaluates current processing capacity.	Performance monitoring evaluates processing capacity.	Inspected capacity and performance monitoring evidence collected throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
A1.2	Provides for environmental protections, backup, and recovery infrastructure.	A redundant secondary system provides recovery capability.	Inspected the configuration evidencing a redundant secondary system and confirmed it remained in place throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
A1.3	Tests recovery plan procedures supporting system recovery.	Contingency plan testing & exercises are performed.	Inspected contingency plan test and exercise records performed during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
C1.1	Identifies and maintains confidential information.	Data & asset classification identifies confidential information.	Inspected the data classification scheme and asset classification records maintained throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
C1.1b	Identifies and maintains confidential information.	Data protection controls safeguard classified data.	Inspected the data protection controls and confirmed they continued to be applied to classified data throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted



TSC Ref	Trust Services Criteria	Control Activity	Test Applied by the Service Auditor	Test Result
C1.1c	Identifies and maintains confidential information.	Information sharing is governed to protect confidential data.	Inspected the information-sharing governance controls and confirmed they remained in place throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
C1.2	Disposes of confidential information to meet objectives.	Media & data retention is governed.	Inspected the media and data retention schedules in effect throughout the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
C1.2b	Disposes of confidential information to meet objectives.	Physical media is securely disposed of.	Inspected physical media disposal records and procedures applied during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted
C1.2c	Disposes of confidential information to meet objectives.	Equipment is securely disposed, destroyed or re-used.	Inspected secure equipment disposal records and procedures applied during the examination period (February 1, 2026 to April 30, 2026).	No Exceptions Noted

*****End Of Report*****